ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.
6. While testing a web application, you find a vulnerability that could allow you to access other clients' data hosted on the same shared server. This is outside your contracted scope. What do you do, and how does this scenario illustrate the limits of ethical hacking engagements?
7. A junior tester on your team wants to use automated exploitation tools without fully understanding what they do, "because it's faster." Using this scenario, explain the risks

of tool-dependent hacking and the professional standards expected of an ethical hacker.

8. Your client's competitor secretly offers you money to share findings from a penetration test you conducted for the client. Analyze this scenario in terms of professional ethics, confidentiality, and potential legal consequences.
9. A 16-year-old finds a flaw in their school's grading portal and quietly emails the administration instead of exploiting it. Classify this individual using standard hacker categorizations and justify your reasoning.
10. An employee, angry after being denied a promotion, uses their legitimate system access to leak internal documents to a journalist. Is this "hacking"? Analyze the actor's classification, motive, and the ethical/legal implications.
11. A security researcher publicly releases a working exploit for a vulnerability before the vendor has issued a patch, arguing that public pressure is the only way to force a fix. Discuss whether this qualifies as ethical hacking, and where this person falls on the hacker spectrum.
12. A nation-state-sponsored group breaches a hospital's systems to disrupt operations during a geopolitical conflict. Analyze this scenario across the categories of hacker types and explain why classification matters for response and law.
13. A person with no malicious intent scans random IP addresses on the internet "just to see what's out there" without permission. Argue both sides: is this person a "grey hat," and what ethical line have they crossed, if any?
14. Two people independently discover the same zero-day vulnerability. One reports it to the vendor; the other sells it on a dark web marketplace. Compare and contrast their classifications, motivations, and the consequences each might face.
15. A company employee is asked by management to secretly access a colleague's email account to gather evidence of misconduct, using company-owned credentials. Is this employee acting as an "ethical hacker"? Defend your position.
16. An AI-powered bot automatically probes IoT devices for default passwords and reports vulnerable devices to a public database without owner consent. Analyze whether the creator of this bot fits any traditional hacker classification, and what new categories might be needed.
17. You're performing an authorized penetration test and discover evidence that an employee of the client company is engaged in a separate, unrelated crime (e.g., embezzlement) unrelated to your scope. What are your ethical obligations, and how do they interact with your contractual scope?
18. A client asks you to test only certain departments, but you strongly suspect the departments excluded from scope contain the greatest security risk (possibly deliberately hidden by executives). Discuss the ethical tension between contractual boundaries and your professional duty to protect the organization.
19. During a social engineering assessment, you successfully manipulate a receptionist into revealing sensitive information by pretending to be a grieving relative of an employee. Evaluate the ethics of this pretext, considering psychological harm versus test realism.

20. You discover a vulnerability so severe that exploiting it, even briefly, could crash critical hospital patient-monitoring systems. Your contract requires "full exploitation to confirm impact." How do you ethically resolve this conflict between contractual obligation and patient safety?
21. Your firm offers a discount to clients who agree to let you reuse "anonymized" data from their penetration test in a public case study or training material. Analyze the ethical issues around consent, anonymization, and confidentiality in this business model.
22. You are asked to test the security awareness of employees by sending a phishing email that impersonates a company layoff announcement, since it's proven to get high click rates. Discuss the ethical boundaries of social engineering tests and psychological impact on staff.
23. A fellow ethical hacker on your team wants to keep a "personal copy" of exploit code and access credentials discovered during a client engagement "in case it's useful later." Analyze the ethical and professional violations in this scenario.
24. You are contracted by a company to test its systems, but during recon you realize the company's core business model itself may be operating a scam that harms consumers. Do professional ethics require you to report this, and to whom, given your role is purely technical?
25. You are hired by a US-based company to test servers that are physically hosted in another country with different (and less protective) cybersecurity laws. Analyze the jurisdictional and legal issues you must resolve before starting the engagement.
26. Midway through a penetration test, the client's CEO verbally tells you to "go ahead and test that system too," but it isn't in the signed Statement of Work. Explain the legal risks of proceeding, referencing the concept of authorization and applicable computer misuse laws.
27. You discover, during an authorized test, a backdoor that appears to have been planted by a previous (unauthorized) attacker who is still actively using it. What are your legal obligations regarding evidence handling, reporting, and potential involvement of law enforcement?
28. A client terminates your penetration testing contract mid-engagement due to a business dispute, but you still have active reverse shells and access credentials on their systems. Explain, step by step, what legal and ethical actions you must take immediately.
29. An ethical hacker signs a contract with vague scope language ("test the network") and later exploits a cloud-based third-party service integrated with the client's systems. The third party threatens legal action. Analyze where liability may fall and how proper scoping and legal documentation could have prevented this.
30. A government asks a security firm to hack into a foreign company's servers "in the national interest," without a formal legal warrant applicable across borders. Discuss the legal and ethical grey areas this creates for the hackers involved, referencing relevant legal frameworks like the Computer Fraud and Abuse Act (or equivalent).

31. You are asked to sign an NDA and a "get out of jail free" authorization letter before a physical penetration test (attempting to break into a building). During the test, local police detain you before you can produce the letter. Explain what legal protections such authorization documents provide, and their limitations in real time.
32. A company's Terms of Service prohibit "unauthorized testing" of their systems, but a security researcher argues that responsibly probing publicly accessible endpoints without causing damage should be legal under public interest research exceptions. Analyze this argument using real-world legal precedent or debate.
33. You discover a critical zero-day vulnerability in widely-used medical device software during an authorized test. The vendor is unresponsive for 90 days despite multiple attempts to contact them. Using a responsible disclosure framework, explain your next steps and justify the timeline.
34. A security researcher publicly tweets details of a vulnerability in a popular banking app within hours of discovering it, without contacting the bank first, citing "the public has a right to know." Analyze this against standard disclosure practices and the potential real-world consequences.
35. You report a vulnerability to a company through their official bug bounty program, but the company threatens legal action against you instead of paying the promised reward, claiming you "exceeded authorized scope." Discuss the disclosure and legal risks researchers face, and how to mitigate them beforehand.
36. During a coordinated disclosure process, the vendor asks you to delay public disclosure indefinitely with no fixed patch timeline, citing "business reasons" unrelated to the technical fix. As the researcher, how do you balance ethical disclosure obligations against vendor pressure?
37. You find a vulnerability affecting an open-source library used by thousands of downstream applications. Disclosing to the maintainer alone won't reach all affected parties quickly. Design a disclosure strategy that balances speed, safety, and coordination across the ecosystem.
38. A company offers you a "hush payment" larger than their bug bounty reward, on the condition you never disclose the vulnerability, even after it's patched. Analyze the ethical implications of accepting this offer versus standard responsible disclosure.
39. You discover a vulnerability while testing one client's system, but the flaw actually exists in a third-party software product used by thousands of other organizations who are not your clients. Explain your ethical and practical disclosure obligations in this multi-party scenario.
40. A rival security researcher discloses a vulnerability you found first, taking public credit, after you had already privately reported it to the vendor under an embargo. Discuss the ethical norms around disclosure credit, embargoes, and how researchers should handle disputes like this professionally.

ANSWERS

19. During a social engineering assessment, you successfully manipulate a receptionist into revealing sensitive information by pretending to be a grieving relative of an employee. Evaluate the ethics of this pretext, considering psychological harm versus test realism.

Understanding of Problem Context (20 marks)

The client has authorized a social engineering assessment, so the *test itself* is legitimate: the organization wants to know whether its front-desk staff can be tricked into disclosing sensitive information. The question is not whether the receptionist may be tested, but whether this particular **pretext** (posing as a grieving relative) is an acceptable way to test her. Three parties are involved: the client (who consented to the test), the tester (who must act within the agreed rules) and the receptionist (who did not consent, cannot opt out and is a real person with real emotions).

The tension is between **test realism** and **psychological harm**. A grief-based story is realistic because real attackers do exploit sympathy, urgency and bereavement. However, the technique works precisely by exploiting a normal human kindness, and it may leave the receptionist feeling guilty, ashamed, manipulated or afraid of being blamed once the truth is revealed. The assets at stake are the sensitive information (confidentiality) and the well-being and dignity of an individual employee.

Application of Concepts (30 marks)

- **Authorization and scope:** every test action must be covered by the written scope and rules of engagement (RoE). Unless the RoE explicitly approved emotional or bereavement pretexts, using one goes beyond the authorization, and an unapproved deception can expose the tester to legal liability.
- **Do no harm / proportionality:** the least harmful method that still proves the weakness must be chosen. Ethical hackers are expected to avoid unnecessary damage, and psychological damage counts as damage.
- **Respect for persons and beneficence (Belmont Report principles used in deception research):** deceiving people is acceptable only when the benefit is real, the risk is minimal, there is no suitable non-deceptive alternative and participants are debriefed afterwards. Bereavement pretexts fail the minimal-risk test.
- **Professional standards:** codes such as the EC-Council and (ISC)² codes of ethics require integrity, protection of people and the public, and acting within the agreement. Frameworks such as PTES, OSSTMM and NIST SP 800-115 also expect social engineering to be planned, approved and controlled.
- **Legal angle:** pretexting and impersonation are crimes when unauthorized (for example, pretexting to obtain customer financial data is prohibited by the US Gramm-Leach-Bliley Act; the Indian IT Act 2000 and the Bharatiya Nyaya Sanhita punish cheating by personation and identity misuse). Only the client's written authorization separates the tester's act from these offences, so the approved pretexts must be listed in advance.

Problem-Solving Approach (20 marks)

A tester can evaluate any pretext in a structured way:

- **Step 1 – Check authorization:** was this kind of pretext approved in the RoE and by the person who can legally approve it?
- **Step 2 – Assess harm:** who is affected, how severe and how reversible is the emotional impact? Grief, illness, children and emergencies are high-harm themes.
- **Step 3 – Look for an equivalent low-harm pretext:** the security weakness is that the receptionist releases information without verifying identity. A courier, a new employee, a vendor, an IT help-desk caller or a job candidate would prove exactly the same weakness without touching anyone's grief.
- **Step 4 – Apply safeguards:** a list of banned pretexts, a point of contact who can stop the test, immediate abort if the target becomes distressed, and no recording of unnecessary personal details.
- **Step 5 – After the test:** debrief the receptionist kindly, report the finding as a *process* failure (no verification procedure), do not name or punish her, and recommend training.

Accuracy of Solution (20 marks)

Evaluation: the pretext was **effective but ethically unacceptable** unless the client had expressly approved it, and even then it should have been avoided. Test realism is a valid goal, but it does not require emotional exploitation; the same vulnerability could have been shown with a neutral story. The benefit gained (proof that staff trust unverified callers) is small compared with the avoidable psychological harm, so the harm outweighs the realism. The finding itself remains valuable and must be reported: the organization lacks a caller-verification procedure.

Corrective actions now: inform the client lead, offer the receptionist a supportive debrief, present her as a victim of a well-designed attack and not as the culprit, remove the grief detail from the public-facing parts of the report, and recommend staff awareness training with a verification script ("call back on the official number").

Clarity (10 marks)

Aspect	Assessment
Was the test authorized?	Yes, the assessment; the grief pretext only if listed in the RoE.
Benefit of realism	Real attackers use sympathy, so it exposes a genuine weakness.
Harm caused	Possible guilt, shame, distrust and fear of blame for the receptionist.
Better alternative	Vendor, courier, new-joiner or help-desk pretext with the same result.
Verdict	Unethical as performed; psychological harm outweighs realism.

20. You discover a vulnerability so severe that exploiting it, even briefly, could crash critical hospital patient-monitoring systems. Your contract requires "full exploitation to confirm impact." How do you ethically resolve this conflict between contractual obligation and patient safety?

Understanding of Problem Context (20 marks)

The contract tells the tester to exploit every finding fully, but this finding sits on a **safety-critical system**: a crash of the patient-monitoring network could blind nurses to alarms and directly endanger lives. The stakeholders are the patients (most vulnerable, no voice in the contract), clinicians, the hospital's management and IT, the device vendor and the security firm. The conflict is therefore between **contractual obligation** (deliver proof of impact) and the **duty to protect life and safety**. In a normal business network availability is important; in a hospital it can be a matter of life and death, which changes what counts as acceptable risk.

An important observation is that the contract wording was probably written with ordinary IT systems in mind. The client most likely wants *evidence of impact*, not an actual outage of a patient-care system, so there is room to satisfy the purpose of the clause without following its literal words.

Application of Concepts (30 marks)

- **Authorization is a ceiling, not an order:** being authorized to do something is not the same as being obliged to do it. The tester keeps professional judgment and may decline an action that is foreseeably dangerous.
- **Non-maleficence (do no harm) and proportionality:** ethical hacking accepts only controlled, necessary risk. Because the possible harm is loss of life and the benefit (proving what is already evident) is small, proportionality fails.
- **CIA triad – availability and safety:** for patient-monitoring systems availability and integrity protect patient safety, so tests must never degrade them without safeguards.
- **Standards and law:** NIST SP 800-115 and PTES stress avoiding disruption of production systems and agreeing on safe testing methods; medical-device safety standards (such as IEC 62304) and regulatory cybersecurity expectations exist because device compromise is a patient-safety risk. Privacy laws (HIPAA, India's DPDP Act 2023) also apply to patient data. A clause that foreseeably endangers lives is unlikely to be defensible, and a tester who causes harm could face negligence claims, so the client's legal counsel should confirm any change.
- **Professional codes:** the (ISC)² and EC-Council codes place protection of society and the public good above the client's convenience, and require honest, timely reporting of serious risks.
- **Responsible disclosure:** a vulnerability of this severity must be escalated at once, and where the flaw is in vendor software, reported to the vendor through coordinated disclosure.

Problem-Solving Approach (20 marks)

- **Step 1 – Stop:** do not run the exploit on the live system and do not "try it briefly." Record what has been found so far.
- **Step 2 – Gather non-intrusive evidence:** confirm the weakness safely with read-only checks such as version and configuration analysis, banner information, traffic review and a harmless proof of concept that changes nothing.

- **Step 3 – Escalate immediately:** contact the named client contacts (CISO and the clinical or biomedical engineering lead) through the agreed secure channel, explain the risk to patient safety in plain language and request a decision.
- **Step 4 – Propose a safe way to prove impact:** reproduce the exploit in a lab or staging copy, use the vendor's simulator, or, if live testing is truly required, test in a planned maintenance window with clinicians present, manual monitoring as fallback, backups, rollback and an abort condition.
- **Step 5 – Formalize in writing:** obtain a signed change to the scope ("impact confirmed by non-destructive methods"). If the client still insists on live exploitation, the tester should refuse or only proceed under documented risk acceptance and the safeguards above.
- **Step 6 – Reduce risk meanwhile:** recommend compensating controls such as network segmentation, access restrictions, monitoring and virtual patching until a fix is available.
- **Step 7 – Report and disclose:** include the finding as critical in the report, with evidence, impact reasoning and remediation, and inform the vendor responsibly.

Accuracy of Solution (20 marks)

Option	Patient safety	Contract	Verdict
Exploit the live system as written	Unacceptable risk of a crash	Followed literally	Reject
Silently skip the exploit	Safe	Breached without notice; risk may stay hidden	Poor practice
Prove impact safely, escalate and get a written scope change	Safe; impact still demonstrated	Purpose of the clause satisfied, change documented	**Recommended**

Resolution: patient safety takes priority over the literal text of the contract. The tester does **not** exploit the production monitoring system, but demonstrates the impact through safe, agreed alternatives, escalates the critical finding immediately, and documents the decision and the contract amendment. This honors the real purpose of the contract (confirming impact so that the hospital can fix the problem) without creating the very harm the test is meant to prevent.

Clarity (10 marks)

Question	Short answer
Should the tester exploit it live?	No – the risk to patients is not acceptable.
How is impact confirmed?	Read-only checks, lab replica or vendor simulator, or a supervised maintenance window.
Who must be told, and when?	The client's CISO and clinical engineering lead, immediately; the vendor through responsible disclosure.
What protects the tester?	A written scope amendment and a documented record of the decision.

Code of Conduct:

I D.Hasini/192425147 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: 

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach

Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand